

Data Privacy Programs and Principles



Hiral Patel
@gisacouncil



**Data
Privacy**

INTRODUCTION

The objective of a data privacy program is to ensure that an organization responsibly manages personal data in compliance with legal and regulatory requirements, thereby safeguarding the rights and privacy of individuals while minimizing risks associated with data breaches and misuse.



Example

An e-commerce company implementing a data privacy program would ensure that customers' personal and transactional information, such as names, addresses, payment details, and purchase histories, is collected only for processing orders and enhancing customer experience, securely stored with encryption, and accessible only to authorized personnel. This program would help the company comply with regulations like GDPR, DPDP, or CCPA, maintaining customer trust and avoiding legal penalties by providing mechanisms for customers to access, correct, and delete their personal data.

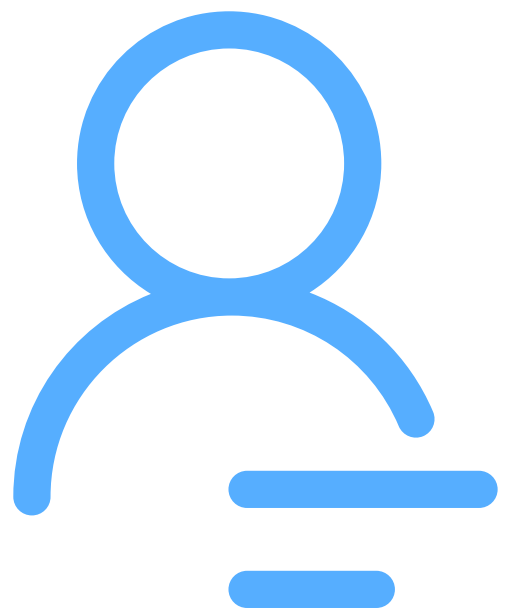


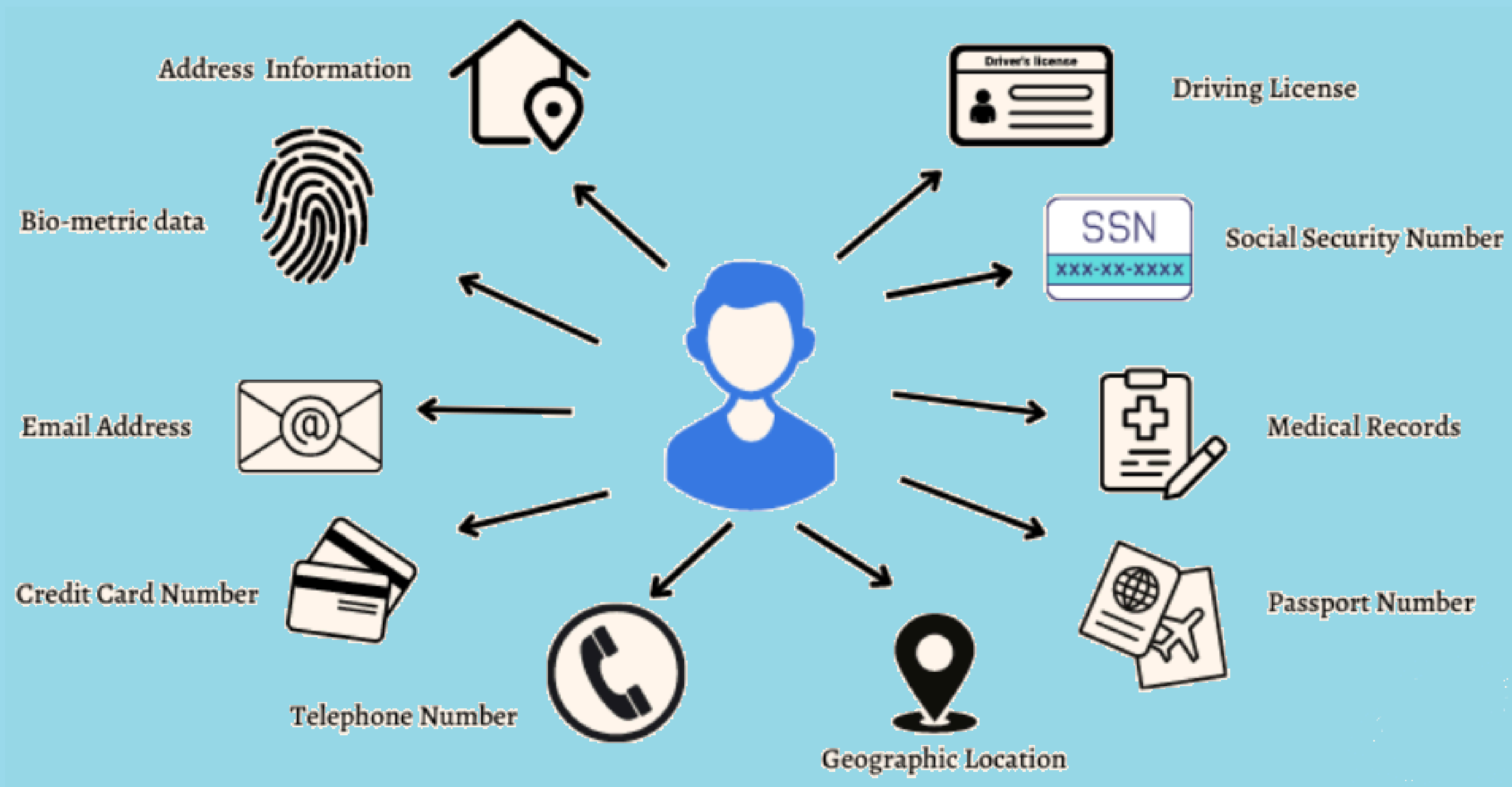


What is PII (Personally identifiable information)?

Personally identifiable information (PII) or personal data, is defined differently in various data protection laws, but generally, it includes any information that can be used to identify a specific individual either directly or indirectly.

Organizations are required to create, implement, and maintain suitable controls to safeguard and manage individuals' privacy throughout the entire life cycle of personal and associated information. This includes identifying internal and external requirements that shape the organization's privacy program and practices.

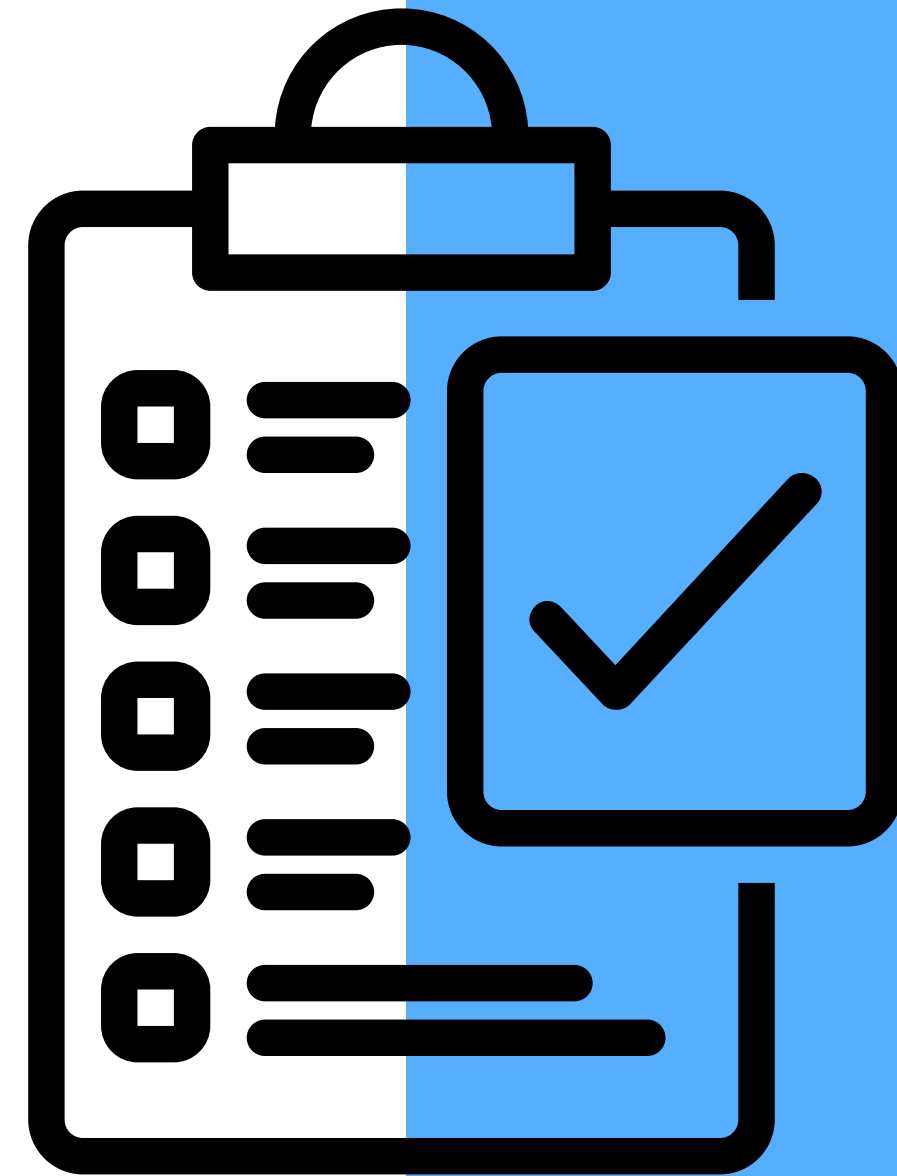




Privacy program Requirements

The requirements for a privacy program can be categorized into:

1. **Internal requirements**
2. **External requirements**



1. Internal Requirement

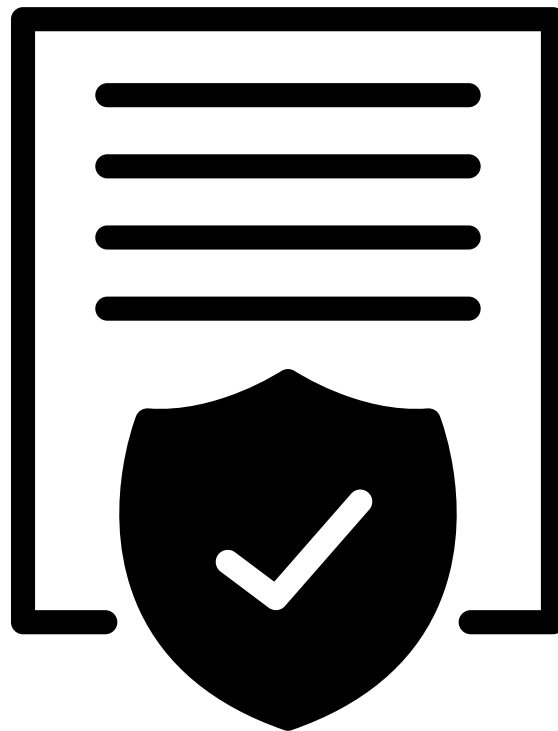
- **Policy and Procedures:** Developing and implementing privacy policies and procedures that outline how personal data will be collected, processed, stored, and protected within the organization.
- **Data Inventory and Mapping:** Conducting a thorough inventory of personal data collected and processed by the organization, and mapping its flow through different systems and processes.
- **Risk Assessment and Management:** Conducting privacy impact assessments (PIAs) and implementing risk management practices to identify and mitigate privacy risks associated with data processing activities.
- **Training and Awareness:** Providing regular training and awareness programs for employees to ensure they understand their responsibilities regarding data protection and privacy.
- **Access Controls:** Implementing technical and organizational measures to restrict access to personal data to authorized personnel only.
- **Incident Response:** Establishing procedures for responding to and reporting data breaches or privacy incidents in a timely manner.

2. External Requirement

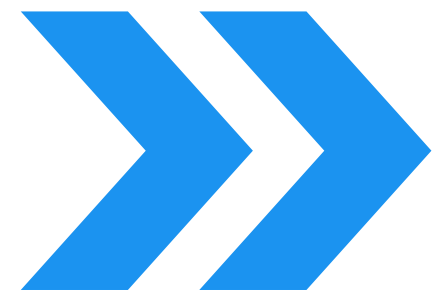
- **Legal and Regulatory Compliance:** Ensuring compliance with relevant privacy laws and regulations applicable to the organization's operations, such as GDPR, CCPA, or local data protection laws.
- **Third-Party Management:** Implementing measures to ensure that third-party vendors and service providers who process personal data on behalf of the organization adhere to the same privacy standards and requirements.
- **Data Subject Rights:** Providing mechanisms for individuals to exercise their rights regarding their personal data, such as access, rectification, erasure, and data portability.
- **Transparency and Accountability:** Being transparent about data processing practices and accountable for compliance with privacy commitments made to individuals and regulatory authorities.
- **International Data Transfers:** Ensuring that any transfer of personal data outside the organization's jurisdiction complies with legal requirements for international data transfers, such as implementing appropriate safeguards under GDPR.

Privacy Documentation

The effective privacy governance program is not possible without documentation. A wide variety of documentation is necessary to support and demonstrate a comprehensive privacy management program and meet variety of privacy legal requirements.



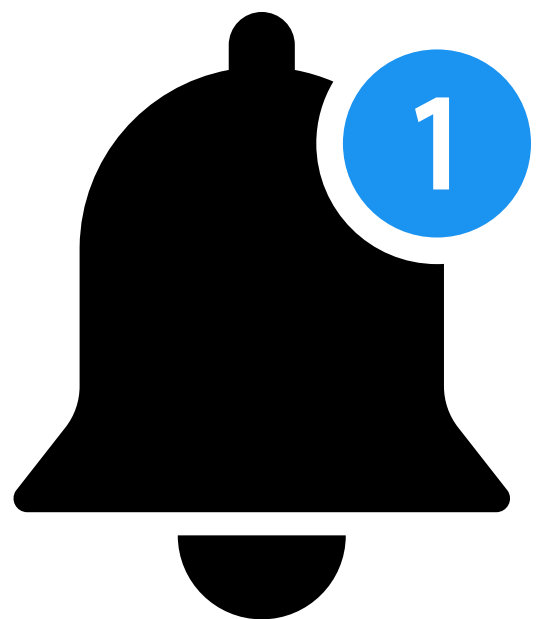
TYPES OF DOCUMENTS



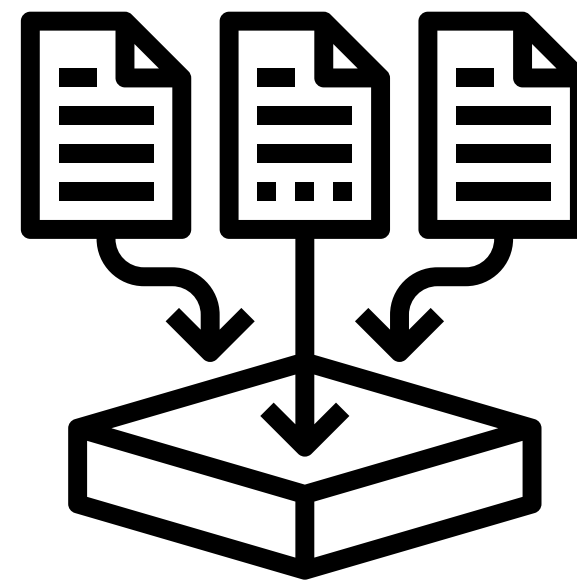
1. Privacy Notice

A privacy notice is an outward-facing document that describes an organization's data handling practices to individuals whose personal data is being collected. It serves as a key transparency mechanism, providing clear and understandable information about how the organization processes, uses, stores, and protects personal data. Key elements typically included in a privacy notice are:

- **Data Controller Identification:** Information about the organization collecting the data and their contact details.
- **Purposes of Data Processing:** Clear explanations of why personal data is being collected and how it will be used.



- **Types of Personal Data:** Description of the categories of personal data being collected (e.g., name, contact details, financial information).
- **Legal Basis for Processing:** Explanation of the legal basis under data protection laws that allows the organization to process personal data (e.g., consent, contractual necessity, legitimate interests).
- **Data Sharing:** Information about whether personal data will be shared with third parties and for what purposes.
- **Data Transfers:** Details on any international transfers of data and safeguards in place to protect data when transferred outside the country.



- **Data Subject Rights:** Explanation of individuals' rights regarding their personal data, such as the right to access, rectify, erase, restrict processing, and object to processing.
- **Data Retention Periods:** Information on how long personal data will be retained or criteria used to determine retention periods.
- **Security Measures:** Description of the security measures in place to protect personal data from unauthorized access, disclosure, alteration, or destruction.
- **Contact Information:** Contact details for individuals to reach out with questions, concerns, or to exercise their data protection rights.





Communication of Privacy notice

Privacy notices should be communicated in a clear, accessible, and understandable manner to ensure individuals are informed about their privacy rights and how their personal data is being handled.

Example:

Signs on buildings or interior walls that inform individuals that closed-circuit television (CCTV) cameras are in use can indeed function as privacy notices. They serve to inform individuals about the presence of surveillance and the collection of their personal data through video recordings.



Here are several effective ways to communicate privacy notices:

- **Website:** Publish the privacy notice prominently on the organization's website. Provide a direct link to the notice from relevant pages, such as the homepage, registration or sign-up pages, and any pages where personal data is collected.
- **Mobile Applications:** Display the privacy notice within the mobile application, accessible through settings or account management sections.





- **Email:** Send a concise summary or link to the full privacy notice in emails where personal data is collected, such as newsletters, promotional emails, or registration confirmations.
- **Paper Forms:** Include a summary or full privacy notice on paper forms where personal data is collected, ensuring it is easily readable.
- **In-Person:** For organizations interacting with individuals face-to-face, provide printed copies of the privacy notice or direct them to where they can access it online.
- **Privacy Dashboard:** Create a dedicated privacy dashboard within user accounts where individuals can access and manage their privacy settings and view the privacy notice.





- **Social Media:** Share links or summaries of the privacy notice on social media channels, particularly if these platforms are used for customer engagement or data collection.
- **Notice Updates:** Notify individuals of updates or changes to the privacy notice through email, website banners, or notifications within mobile applications, with a summary of changes and a link to the updated notice.
- **Multilingual:** Provide translations of the privacy notice where necessary to accommodate diverse language preferences among users.
- **Accessibility:** Ensure the privacy notice is accessible to individuals with disabilities, following accessibility guidelines for web content and documents.

2. Consent Form



- Consent form is Used to document the agreement of data subjects with privacy terms.

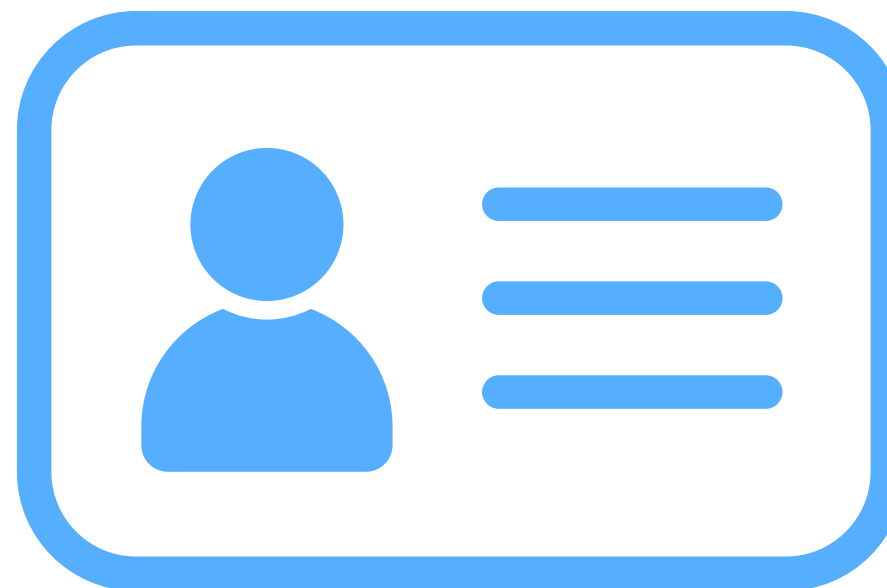
Example

Before participating in an online survey, respondents are required to check a box indicating their consent to the collection and use of their responses for research purposes, with a clear explanation of how their data will be used and protected.

- A consent form could be a button you click to agree or disagree, a box you check on a website below a privacy notice, or a place where you sign on paper forms that have similar privacy information.
- Data subjects have the right to withdraw their consent at any time, and mechanisms used to capture consent should take into account the potential for a data subject to do so.

3. Personal Information Inventory

A personal information inventory is a structured record or database that organizations maintain to catalog and manage all the personal data they collect, process, store, or share. It serves as a comprehensive list detailing the types of personal information held, the purposes for which it is used, the legal basis for processing, retention periods, and any third parties with whom the data is shared. This inventory helps organizations ensure compliance with data protection regulations, assess data risks, and implement appropriate data protection measures.



4. Activity Logs

Activity logs are detailed records that document all actions and events related to the processing of personal data within an organization's IT systems. These logs serve multiple purposes, including monitoring data access and usage, detecting unauthorized activities, facilitating compliance audits with data protection regulations like GDPR or CCPA, aiding in incident response and investigation during data breaches, and maintaining accountability by demonstrating adherence to privacy principles.



5. Data protection legal requirement



Organizations must conduct a comprehensive analysis to identify and document all relevant data protection legal requirements applicable to their operations. This involves researching and understanding data protection laws in jurisdictions where they operate or process personal data, mapping out data flows to pinpoint where legal obligations apply throughout the data lifecycle, and documenting specific requirements such as lawful bases for processing, individuals' rights, data security measures, breach notification obligations, and rules for international data transfers. Implementation of compliance measures, including policies, procedures, and staff training, ensures adherence to these requirements. Regular monitoring and updating of documentation and practices are essential to adapt to evolving regulatory landscapes and maintain robust data protection practices that safeguard individuals' privacy rights.

6. Privacy risk assessment report

A privacy risk assessment report is a structured evaluation that systematically analyzes how an organization handles personal data across its operations and with third-party services. It identifies potential vulnerabilities, threats, and risks to individuals' privacy, assesses the likelihood and impact of these risks, and recommends mitigating measures. The report serves to provide an overview of the organization's privacy risk posture, support compliance with data protection regulations, guide the implementation of effective data protection measures, and enhance transparency and accountability in data processing practices.



7. Training activities

It is important to document when training occurs, the topic of the training, those who attended the training, and the date and time of the training. In addition, it is important to document how the training was delivered and the results of any quizzes or tests provided to the training attendees.

8. Data incident register

Records all personal data incidents. It must contain the fact about the incident, effects of the breach, remedial measures and preventive measures to avoid the breach in future.



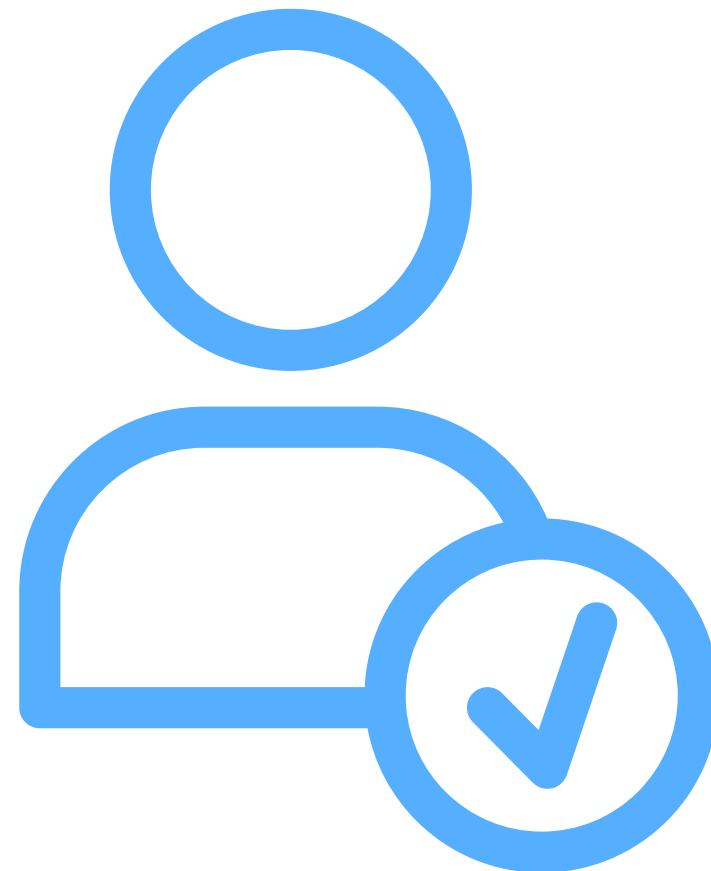
9. Individual rights register

Typically includes a structured record or database that documents and manages requests and actions related to individuals' rights concerning their personal data.

Here's what is generally included in an individual rights register:

- **Access Requests:** Records of requests from individuals seeking access to their personal data held by the organization
- **Rectification Requests:** Documentation of requests from individuals to correct or update inaccurate or incomplete personal data.
- **Erasure Requests (Right to be Forgotten):** Records of requests from individuals to delete their personal data

- **Restriction of Processing Requests:** Documentation of requests from individuals to restrict the processing of their personal data
- **Withdrawal of Consent Requests:** Information on requests from individuals to withdraw previously given consent for specific data processing activities, and the impact of such withdrawals on data processing.



Auditing Data Privacy controls

A data privacy audit is a systematic evaluation of an organization's data protection practices, policies, and procedures to assess compliance with data protection laws and regulations.

It typically involves the following key controls -

1. Policy and Procedure Evaluation:

Review and assess the effectiveness of policies and procedures related to data privacy to ensure they are current, robust, and aligned with regulatory requirements.





2. Data Handling and Processing

Review controls governing how personal data is collected, used, processed, stored, and transferred. Ensure adherence to data minimization principles and lawful processing requirements.

3. Consent Management

Evaluate procedures for obtaining, managing, and documenting individuals' consent for data processing activities, ensuring compliance with consent requirements under data protection laws.

4. Handling of Data Subject Requests

Auditors evaluate how well the organization responds to requests from individuals seeking to access, correct, or delete their personal data, ensuring compliance with legal obligations.

5. Third-Party Management:

Evaluate controls over third-party service providers and vendors that process personal data on behalf of the organization. This includes contractual agreements, security assessments, and monitoring of third-party compliance with data protection obligations.

6. Data Retention and Disposal:

Assess policies and procedures for retaining personal data only for as long as necessary for the purposes for which it was collected, and securely disposing of data that is no longer needed.

7. Cross-Border Data Regulations

Auditors ensure that cross-border data transfers comply with international privacy laws. For example, they verify compliance with GDPR when data is transferred between the EU and the US.

8. Access Controls:

Evaluate controls that restrict access to personal data based on roles and responsibilities, ensuring only authorized individuals have access. This includes authentication mechanisms, user access reviews, and segregation of duties.

9. Data Encryption:

Assess encryption methods used to protect sensitive personal data both at rest (stored data) and in transit (data being transmitted), ensuring encryption standards are in line with best practices and regulatory requirements.



9. Incident Response and Data Breach Management:

Review the organization's incident response plan for detecting, responding to, and mitigating data breaches. Evaluate procedures for notifying affected individuals and regulatory authorities as required by law.

10. Training and Awareness:

Review training programs and awareness initiatives for employees regarding data protection laws, policies, and procedures. Ensure employees understand their roles and responsibilities in protecting personal data.



FOOD FOR THOUGHT

As an IS auditor, you are assessing a company's data privacy program. During your review, you find that the company's privacy policy lacks specific details on how personal data is collected, used, and shared with third parties. Which of the following actions should you recommend FIRST to improve the company's data privacy program?

- A) Conducting a comprehensive privacy impact assessment (PIA)
- B) Updating the privacy policy to include detailed data handling practices
- C) Implementing encryption for all stored personal data
- D) Training employees on data protection regulations and best practices

Thank You

I hope it was useful

Follow me on LinkedIn for more content

CONTACT INFO



+91 960-110-3255



HIRALAPATEL

